

AnkaCORE26

Siber Güvenlik Mühendisliđi Eđitimi - 2026

101 Aşaması Bitirme Projesi

İsim-Soyisim : Hatice Betül ALTAY

Tarih : 03.03.2026

İÇİNDEKİLER

Bölüm A.....	3
1. İşletim Sistemi ve Şifreleme	
2. Web Mimarisi	
3. Ağ Anatomisi	
Bölüm B: Saha Operasyonu.....	4
Cephe 1: İşletim Sistemleri Ustası.....	4
Cephe 2: Web Mantık Avcısı.....	7
Cephe 3: Kör Nokta Dedektifi.....	10

FAZ 1: "Siber Triatlon" Operasyon Raporu

Bölüm A: Teori ve Mimari (Research & Logic) :

1. İşletim Sistemi ve Şifreleme: "Anahtarlar Kimde?"

SSH Private Key (Gizli Anahtar): Parola (Password) ile giriş yapmak varken, sunuculara bağlanırken neden SSH Anahtarları (Public/Private Key) kullanırız? Bu sistemin güvenliğini sağlayan temel mantık nedir?

- İnsanlar genellikle şifrelerini basit seçme eğilimindedirler. SSH Private Key ise bunu çok uzun ve tahmin edilmesi neredeyse imkansız anahtarlar kullanarak çözer. Mantığı ise kullanıcı private key ile kendini doğrular, sunucu ise bunu public key ile kontrol eder.

Hex Dump: Bilgisayarlar için yazılmış binary (ikili) dosyaları okunabilir hale getiren "Hex Dump" nedir?

- Hex dump, bir dosyanın ham verisini (0 ve 1'leri) insanların anlayabileceği şekilde hexadecimal olarak gösteren çıktıdır. Bu sayede dosya analizi yapılabilir.

2. Web Mimari: "Sunucu Tarafı (Server-Side)"

Client-Side vs Server-Side: Bir web sayfasında "Sağ tık > Kaynağı İncele" dediğimizde HTML ve JavaScript kodlarını (Client-side) görebilirken, neden PHP veya Python (Server-side) kodlarını göremeyiz?

- PHP veya Python kodları sunucuda çalışır. Bu kodlar sunucuda çalıştırılır ve sonucunda oluşan hazır HTML çıktısı kullanıcıya gönderilir. Kodun kendisi gönderilmez.

Command Injection (Komut Enjeksiyonu): Bir web sitesindeki arama kutusuna yazılan masum bir metin, nasıl olur da arka plandaki Linux sunucusunda ls veya whoami komutlarının çalışmasına neden olur?

- Saldırgan arama kutusuna özel karakterler veya komutlar yazarsa, bu veri sunucuda çalıştırılan komuta eklenebilir ve ls, whoami gibi Linux komutlarının çalışmasına neden olabilir. Kullanıcı girdisi doğru filtrelenmezse saldırgan sunucuda kendi komutlarını çalıştırabilir.

3. Ağ Anatomisi: "Avin İzleri"

C2 (Command and Control) Nedir? Bir bilgisayara zararlı yazılım (Malware) bulaştığında, bu yazılım neden hacker'ın "C2 Sunucusuna" bağlanma ihtiyacı duyar?

- Bir bilgisayara zararlı yazılım bulaştığında, bu yazılım C2 sunucusuna bağlanarak hacker'dan komut alır. Böylece hacker bilgisayara ne yapacağını söyleyebilir. C2 sunucusu, zararlı yazılım bulaşmış bilgisayarları uzaktan yönetmek için kullanılan kontrol merkezidir.

PCAP Analizi: Bir SOC (Güvenlik Operasyon Merkezi) analisti, zararlı yazılımı tespit etmek için neden sadece antivirüs loglarına güvenmez de ağdaki PCAP (Packet Capture) dosyasını inceleme ihtiyacı duyar?

- çünkü antivirüs bazı zararlı yazılımları kaçırabilir veya hiç log üretmeyebilir. PCAP dosyası ise ağdaki tüm paketleri gösterir. Analist bu sayede bilgisayarın hangi IP'lere bağlandığını, ne veri gönderdiğini ve şüpheli trafik olup olmadığını görebilir.

Bölüm B: Saha Operasyonu (Boss Fights)

Cephe 1: İşletim Sistemleri Ustası (Linux / Bash)

Level 11 :

- Dosyayı görmek için cat data.txt komutunu çalıştırdım

```
bandit11@bandit: ~  
Finally, network-access is limited for most levels by a local  
firewall.  
  
--[ Tools ]--  
  
For your convenience we have installed a few useful tools which you can find  
in the following locations:  
  
* gef (https://github.com/hugsy/gef) in /opt/gef/  
* pwndbg (https://github.com/pwndbg/pwndbg) in /opt/pwndbg/  
* gdbinit (https://github.com/gdbinit/gdbinit) in /opt/gdbinit/  
* pwntools (https://github.com/Gallopsled/pwntools)  
* radare2 (http://www.radare.org/)  
  
--[ More information ]--  
  
For more information regarding individual wargames, visit  
http://www.overthewire.org/wargames/  
  
For support, questions or comments, contact us on discord or IRC.  
  
Enjoy your stay!  
  
bandit11@bandit:~$ cat data.txt
```

- ROT13 şifrelemesini çözmek için de tr 'A-Za-z' 'N-ZA-Mn-za-m' < data.txt komutunu çalıştırdım ve sonucu buldum

```
bandit11@bandit: ~  
* radare2 (http://www.radare.org/)  
  
--[ More information ]--  
  
For more information regarding individual wargames, visit  
http://www.overthewire.org/wargames/  
  
For support, questions or comments, contact us on discord or IRC.  
  
Enjoy your stay!  
  
bandit11@bandit:~$ cat data.txt  
Gur cnffjbeq vf 7k16JARUVv5LxVuJfsSVdbbtaHGlw9D4  
bandit11@bandit:~$ cat data.txt | 'A-Za-z' 'N-ZA-Mn-za-m'  
A-Za-z: command not found  
bandit11@bandit:~$ whoami  
bandit11  
bandit11@bandit:~$ ls  
data.txt  
bandit11@bandit:~$ cat data.txt  
Gur cnffjbeq vf 7k16JARUVv5LxVuJfsSVdbbtaHGlw9D4  
bandit11@bandit:~$ tr 'A-Za-z' 'N-ZA-Mn-za-m' < data.txt  
The password is 7x16WNeHIi5YkIhWsFfIqoognUTyj9Q4  
bandit11@bandit:~$
```

7x16WNeHIi5YkIhWsFfIqoognUTyj9Q4

Level 12 :

- önce dosya için geçici klasör oluşturdum ve içine girip dosyayı kopyaladım

```
bandit12@bandit:~$ mkdir -p /tmp/tmp.zgmGZmyOEq
bandit12@bandit:~$ cp ~/data.txt .
cp: '/home/bandit12/data.txt' and './data.txt' are the same file
bandit12@bandit:~$ cd /tmp/tmp.zgmGZmyOEq
bandit12@bandit:/tmp/tmp.zgmGZmyOEq$ cp ~/data.txt .
bandit12@bandit:/tmp/tmp.zgmGZmyOEq$
```

- Dosyayı sorguladım, gzip olduğunu öğrendim ve dosya katmanlı olduğu için çıkan katmana göre dosyayı açarak şifreyi buldum

```
data6.bin data.tar data.txt
bandit12@bandit:/tmp/tmp.4h9RmxW3AJ$ file data6.bin
data6.bin: bzip2 compressed data, block size = 900k
bandit12@bandit:/tmp/tmp.4h9RmxW3AJ$ mv data6.bin data.tar
bandit12@bandit:/tmp/tmp.4h9RmxW3AJ$ tar -xf data.tar
bandit12@bandit:/tmp/tmp.4h9RmxW3AJ$ ls
data8.bin data.tar data.txt
bandit12@bandit:/tmp/tmp.4h9RmxW3AJ$ file data
data: cannot open `data' (No such file or directory)
bandit12@bandit:/tmp/tmp.4h9RmxW3AJ$ mv data6.bin data.bz2
mv: cannot stat 'data6.bin': No such file or directory
bandit12@bandit:/tmp/tmp.4h9RmxW3AJ$ file data8.bin
data8.bin: gzip compressed data, was "data9.bin", last modified: Tue Oct 14 09:26:06 2025, max compression, from Unix, original size modulo 2^32 49
bandit12@bandit:/tmp/tmp.4h9RmxW3AJ$ mv data8.bin data.gz
bandit12@bandit:/tmp/tmp.4h9RmxW3AJ$ gunzip data.gz
bandit12@bandit:/tmp/tmp.4h9RmxW3AJ$ ls
data data.tar data.txt
bandit12@bandit:/tmp/tmp.4h9RmxW3AJ$ file data
data: ASCII text
bandit12@bandit:/tmp/tmp.4h9RmxW3AJ$ cat data
The password is F05dwFsc0cbaIiH0h8J2eUks2vdTDwAn
F05dwFsc0cbaIiH0h8J2eUks2vdTDwAn
```

Level 13 :

- Level 13'te bir sonraki seviyenin şifresi doğrudan verilmemiştir. Bunun yerine sshkey.private isimli bir SSH Private Key dosyası verilmiştir. Bu anahtar kullanılarak bandit14 kullanıcısına giriş yapılması gerektiğini gördüm. Ve dosyayı bilgisayarıma indirdim

```
bealt@betul MINGW64 ~
$ scp -P 2220 bandit13@bandit.labs.overthewire.org:sshkey.private .

      _|_|_ _|_|_ _|_|_ _|_|_ _|_|_ _|_|_ _|_|_ _|_|_ _|_|_
      | | _ \ / _ \ / _ \ / _ \ / _ \ / _ \ / _ \ / _ \ / _ \
      | | _ \ / _ \ / _ \ / _ \ / _ \ / _ \ / _ \ / _ \ / _ \
      | | _ \ / _ \ / _ \ / _ \ / _ \ / _ \ / _ \ / _ \ / _ \

This is an OverTheWire game server.
More information on http://www.overthewire.org/wargames

backend: gibson-1
bandit13@bandit.labs.overthewire.org's password:
sshkey.private                                100% 1679      9.4KB/s   00:00

bealt@betul MINGW64 ~
$ ls
```

- Dosyaya girme izni verdim

```
--[ Tools ]--

For your convenience we have installed a few useful tools which you can find
in the following locations:

* gef (https://github.com/hugsy/gef) in /opt/gef/
* pwndbg (https://github.com/pwndbg/pwndbg) in /opt/pwndbg/
* gdbinit (https://github.com/gdbinit/Gdbinit) in /opt/gdbinit/
* pwntools (https://github.com/Gallopsled/pwntools)
* radare2 (http://www.radare.org/)

--[ More information ]--

For more information regarding individual wargames, visit
http://www.overthewire.org/wargames/

For support, questions or comments, contact us on discord or IRC.

Enjoy your stay!

bandit14@bandit:~$ cat /etc/bandit_pass/bandit14
MU4VWeTyJk8R0of1qqmcBPALh7lDCPvS
bandit14@bandit:~$
```

- Yeni terminalden bandit14'e bağlandım ve cat ile şifresini aldım

```
bealt@betul MINGW64 ~
$ chmod 600 sshkey.private

bealt@betul MINGW64 ~
$
```

MU4VWeTyJk8R0of1qqmcBPALh7lDCPvS

Level 14 :

- öncelikle bandit14 kullanıcısının parolası cat ile okundu ve sunucu ile bağlantı kurmak için netcat aracı kullandım

```
bandit14@bandit:~$ nc localhost 30000
```

Bu komut ile localhost üzerindeki 30000 portuna bir TCP bağlantısı açılmıştır. Bağlantı kurulduktan sonra Level 14 parolası terminal üzerinden gönderilmiştir.

```
MU4VWeTyJk8R0of1qqmcBPALh7lDCPvS
Correct!
8xCjnmgoKbGLhHFAZlGE5Tmu4M2tKJQo
```

8xCjnmgoKbGLhHFAZlGE5Tmu4M2tKJQo

Level 15 :

```
--[ More information ]--

For more information regarding individual wargames, visit
http://www.overthewire.org/wargames/

For support, questions or comments, contact us on discord or IRC.

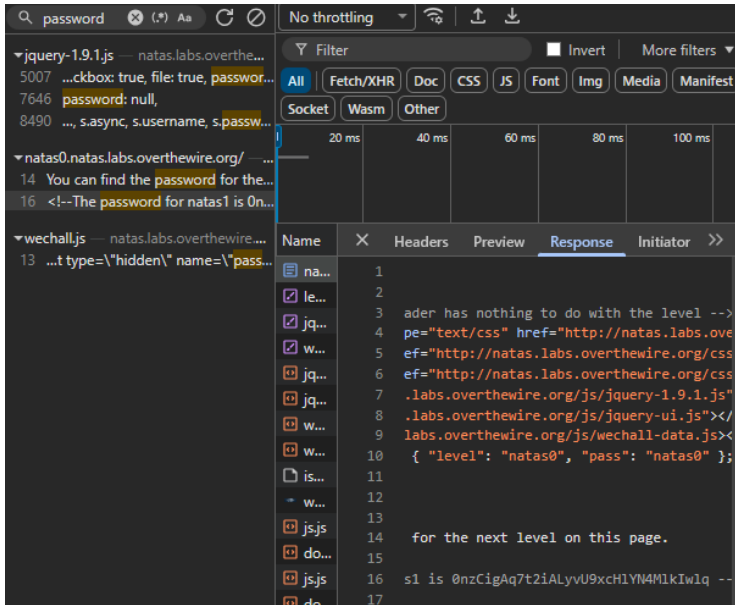
Enjoy your stay!

bandit15@bandit:~$ cat /etc/bandit_pass/bandit15
8xCjnmgoKbGLhHFAZlGE5Tmu4M2tKJQo
8xCjnmgoKbGLhHFAZlGE5Tmu4M2tKJQo
```

Cephe 2: Web Mantık Avcısı (Server-Side)

Level 0 :

- İlk olarak öğeyi denetle ile network'ü açtım. İsteklere baktım ve belki unutulmuştur diyerek password'ü arattım ve şifreye ulaştım

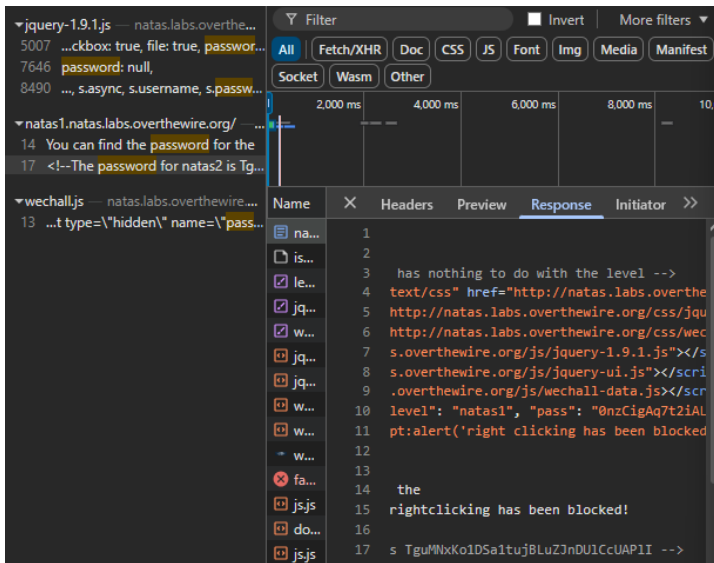


0nzCigAq7t2iALyvU9xcHlYN4MlkIwlq

- Information Disclosure

Level 0 – Level 1 :

- Level 0 'da yapılan adımları yaptım ve aynı şekilde unutulmuş şifreyi buldum.

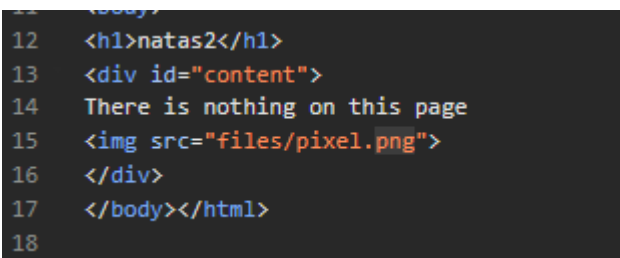


TguMNxKo1DSa1tujBLuZJnDUICcUAP1I

- Client-side security control bypass

Level 1 – Level 2 :

- Bu bölümde incele seçeneği blokluydu bende f12 kullandım ama bu sefer password aratanca hiçbir şey çıkmadı ama bir png dosyası buldum



- Bunu bulmak için adresi değiştirdim <http://natas2.natas.labs.overthewire.org/files/> ve buradan da şifreyi buldum

```
# username:password
alice:BYNdCesZqW
bob:jw2ueICLvT
charlie:G5vCxkVW3m
natas3:3gqisGdR0pjm6tpkDKdIW02hSvchLeYH
eve:zo4mJWyNj2
mallory:9urtcpzBmH
```

3gqisGdR0pjm6tpkDKdIW02hSvchLeYH

- Directory Listing

Level 2 – Level 3 :

- Bu bölümde de sırayla adımları yaptım ama bir şey çıkmadı bu sefer robots.txt denemeye karar verdim ve böyle bir çıktı aldım

```
User-agent: *
Disallow: /s3cr3t/
```

- Bu sefer de bu /s3cr3t/ yoluna bakmak istedim ve içerisinde user.txt dosyası vardı ve şifreyi aldım

```
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 3.2 Final//EN">
<html>
  <head>
    <title>Index of /s3cr3t</title>
  </head>
  <body>
    <h1>Index of /s3cr3t</h1>
    <table>
      <tr><th valign="top"></th><th><a href="?C=N;O=D">Name</a></th><th><a href="?C=
      <tr><th colspan="5"><hr></th></tr>
      <tr><td valign="top"></td><td><a href="/">Parent Directory</a></td><td align="rig
      <tr><td valign="top"></td><td><a href="users.txt">users.txt</a></td><td align="rig
      <tr><th colspan="5"><hr></th></tr>
    </table>
    <address>Apache/2.4.58 (Ubuntu) Server at natas3.natas.labs.overthewire.org Port 80</address>
  </body></html>
```

QryZXc2e0zahULdHrtHxzyYkj59kUxLQ

- Information Disclosure via robots.txt

Level 3 – Level 4 :

- Burada da önceki adımları yapmaya çalıştım ama bir cevap alamadım ve burp suit'te bakmaya karar verdim Proxy ile açtığım sitenin isteklerini repeater'a attım ve referer satırı ekleyerek şifreyi buldum

Request	Response
<pre>1 GET / HTTP/1.1 2 Host: natas4.natas.labs.overthewire.org 3 Referer: http://natas5.natas.labs.overthewire.org/ 4 Cache-Control: max-age=0 5 Authorization: Basic bmFOYXMOOlFyeVpYzJlMHphaFVhZDhEh4enlZa2o1OWtVeExR 6 Accept-Language: tr-TR,tr;q=0.9 7 Upgrade-Insecure-Requests: 1 8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36 9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image /webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7 10 Accept-Encoding: gzip, deflate, br 11 Connection: keep-alive 12 13</pre>	<pre>17 </script> 18 <script src= http://natas.labs.overthewire.org/js/jquery-ui.js"> </script> 19 <script src= http://natas.labs.overthewire.org/js/wechall-data.js"> </script> 20 <script src="http://natas.labs.overthewire.org/js/wechall.js "> 21 </script> 22 var wechallinfo = { 23 "level": "natas4", "pass": 24 "QryZXc2e0zahULdHrtHxzyYkj59kUxLQ" 25 }; 26 </script> 27 </head> 28 <body> 29 <h1> 30 natas4 </h1> <div id="content"> Access granted. The password for natas5 is On35PkggAPm2zbEpOU802c0x0Msn1ToK
 <div id="viewsource"> Refresh page </div> </div> </body> </html></pre>

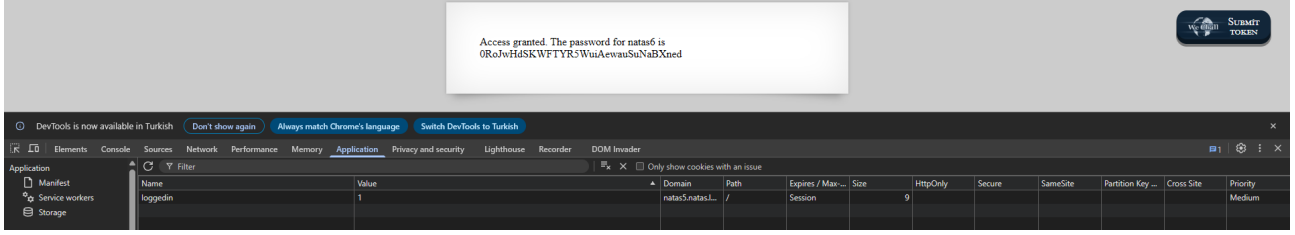
On35PkggAPm2zbEpOU802c0x0Msn1ToK

- Referer-Based Access Control Bypass

Level 4 – Level 5 :

- Sayfada You are not logged in hatası aldığımızı fark ettim. Cookie’lerde bir şeyler olup olamayacağına bakmak istedim ve loggedin 0 değerini gördüm. Değeri 1 ile değiştirip f5 yaptığımızda natas6’nın şifresi görüldü.

NATAS5



0RoJwHdSKWFTYR5WuiAewauSuNaBXned

- Authentication Bypass via Cookie Manipulation

Level 5 – Level 6 :

- Sayfaya giriş yapıldığında input secret olduğunu görüyoruz ve altında view sourcecode bölümünü görüyoruz. Buraya tıkladım ve içinde bir şey fark ettim.

```
include "includes/secret.inc";
```

- Bu adrese gittiğimizde de secret’a erişmiş oluyoruz

```
<?
$secret = "FOEIUWGHFEEUHOFUOIU";
?>
```

- Input’u yerine yazdığımızda da şifreyi buluyoruz

Access granted. The password for natas7 is
bmg8SvU1LizuWjx3y7xkNERkHxGre0GS
Input secret:

[View sourcecode](#)

bmg8SvU1LizuWjx3y7xkNERkHxGre0GS

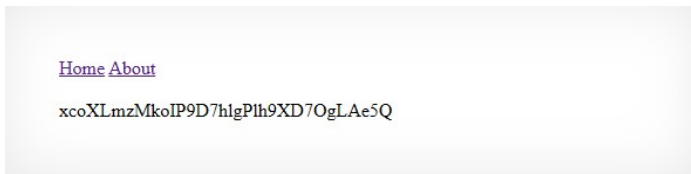
- Exposed Internal File

Level 6 – Level 7 :

- Sayfayı inceleyip network’e girdiğimde bir ipucuyla karşılaştım

```
11 <!-- hint: password for webuser natas8 is in /etc/natas_webpass/natas8 -->
```

- Bu adrese girdim ve şifre görüldü



xcoXLmzMkoIP9D7hlgPlh9XD7OgLAe5Q

- Local File Inclusion

Level 7 – Level 8 :

- Bu sayfada da aynı şekilde Input Secret kısmı vardı ve alt tarafta view sourcecode linki vardı. Bu linke gittiğimde de karşıma böyle bir şey çıktı.

```
$encodedSecret = "3d3d516343746d4d6d6c315669563362";
```

- Devamında da hangi sırayla encode edildiği yazıyordu. Bende tersine açarak şifreyi bulmaya çalıştım.

```
function encodeSecret($secret) {  
    return bin2hex(strrev(base64_encode($secret)));  
}
```

Hex – text : ==QcCtmMml1ViV3b

String reverse : b3ViV1lmMmtCcQ==

base64 : oubWYf2kBq

- Bu input'u gönderdiğimde de şifre gözüksü

Access granted. The password for natas9 is
ZE1ck82lmdGIoErlhQgWND6j2Wzz6b6t

ZE1ck82lmdGIoErlhQgWND6j2Wzz6b6t

- Security through Obscurity

Level 8 – Level 9 :

- Sayfada bizden yine bir input alanı verilmiş ve verisi isteniyor ve altında da yine view sourcecode alanı verilmiş. Burada da şöyle bir alanla karşılaştım.

```
if($key != "") {  
    passthru("grep -i $key dictionary.txt");  
}
```

- Sayfa kullanıcıdan aldığı girdiyi herhangi bir filtreleme yapmadan doğrudan shell komutuna eklemektedir. Ben de ; cat /etc/natas_webpass/natas10 payload'u kullanılarak komut zincirleme yaptım ve parolaya ulaştım.

Output:

t7I5VHvpa14sJTUGV0cbEsbYfFP2dmOu

t7I5VHvpa14sJTUGV0cbEsbYfFP2dmOu

- Command Injection

Cephe 3: Kör Nokta Dedektifi (Ağ Adli Analizi)

1. Soru : Bizden zararlı yazılımla ilk iletişimin saatini ve yılını istemişler. Öncelikle tüm http paketlerini göstermesi için 'http' yaparak listeledim ve tarihe göre sıraladım ve tarih ve saatini buldum

No.	Time	Source	Destination	Protocol	Length
1735	2021-09-24 16:44:38.990412	10.9.23.102	85.187.128.24	HTTP	514
2173	2021-09-24 16:44:41.976037	85.187.128.24	10.9.23.102	HTTP	514
3822	2021-09-24 16:46:16.395000	10.9.23.102	208.91.128.6	HTTP	288
3851	2021-09-24 16:46:17.143575	208.91.128.6	10.9.23.102	HTTP	60
3908	2021-09-24 16:46:41.509097	10.9.23.102	208.91.128.6	HTTP	288
3912	2021-09-24 16:46:42.285190	208.91.128.6	10.9.23.102	HTTP	60
3996	2021-09-24 16:47:06.571342	10.9.23.102	208.91.128.6	HTTP	288
4000	2021-09-24 16:47:07.287902	208.91.128.6	10.9.23.102	HTTP	60

2. Soru : Bu soruda da bizden indirilen zip dosyasının adı isteniyor. Öncelikle zip dosyası olduğunu bildiğim için .zip olarak filtreleme yaptım frame contains ".zip" bu komutla ve çıkan 2 dosyadan http isteği olana baktığımda dosyanın documents.zip olduğunu buldum

No.	Time	Source	Destination	Protocol	Length	Info
1735	2021-09-24 16:44:38.990412	10.9.23.102	85.187.128.24	HTTP	514	GET

3. Soru : Alan adını soruyor aynı yerden bu bilgiye de ulaşabiliyoruz

```
GET /incidunt-consequatur/documents.zip HTTP/1.1\r\n
Host: attirenepal.com\r\n
```

4. Soru : Dosyayı indirmeden, zip dosyasındaki dosyanın adı nedir? Burada da aynı ip adresindeki .zip dosyası bölümüne http stream ile açtıktan sonra dosyanın adını bulabildim

```
..chart-1530076591.xlsUT
```

5. Soru : Zip dosyasının indirildiği kötü amaçlı IP'nin web sunucusunun adı nedir? Yine aynı yerden cevabı bulabiliyoruz

```
server: LiteSpeed
```

6. Soru : Önceki sorudaki web sunucusunun sürümü nedir? Bu sorunun da cevabı aynı yerde

```
x-powered-by: PHP/7.2.34
```